MODULE 02 · SECTION 1 - DESIGNING DATA PROCESSING SYSTEMS

IAM and Organisation Policies for Data

Who can touch the data, which identity a pipeline runs as, and the rules nobody can break.

SECTION 1 of 5 EXAM WEIGHT 22% MODULE 2 of 45

admin@sthithapragna.com

An IAM grant only ever adds access. To **take access away**, you need a different tool.

Grants flow down, never up

01

Organisation

larkspur.energy. A grant here reaches everything.

02

Folder

uk, de and shared. Groups projects by country or team.

03

Project

lk-warehouse-prod. Where billing and most grants live.

04

Dataset or bucket

curated, raw, marts. The usual home for data grants.

05

Table or view

The finest level. Use it when a dataset is too broad.

ON THE EXAM

A role granted at the organisation reaches every table in every project. No lower grant can switch it off.

Basic, predefined, custom

KIND	EXAMPLES	VERDICT
Basic	Owner, Editor, Viewer	Avoid. Google says they grant excessive and uneven access.
Predefined	BigQuery Data Viewer, Dataflow Worker	The default answer. Built by Google, kept up to date.
Custom	Your own list of permissions	Only when no predefined role is narrow enough. You maintain it.

THE DETAIL THEY TEST

Custom roles live at the organisation or a project, never a folder. An option that says otherwise is wrong.

The BigQuery roles worth knowing

ROLE	WHAT IT LETS YOU DO	LOWEST LEVEL
Data Viewer	Read tables and their metadata	Table
Data Editor	Read and change tables, views, routines	Table
Data Owner	Everything above, plus manage access	Table
Metadata Viewer	See schemas and access, not the data	Table
Job User	Run jobs and queries in a project	Project
User	Run jobs, and create datasets	Project
Admin	Everything in the project	Project

THE TIEBREAKER

Data roles say what you can read. Job User says where you can run the query. Most people need one of each.

Reading data is not the same as running a query

DATA VIEWER

What you can read

- Granted where the data lives
- On a dataset, table or view
- Has no permission to run jobs
- Alone, it cannot run a query

JOB USER

Where the query runs

- Granted where the work is billed
- On a project only
- Has no permission to read data
- Alone, it reads nothing

THE PATTERN

Larkspur analysts get Job User on lk-analytics-prod, and Data Viewer on the curated dataset only.

Granting a dataset role in SQL

```
1 -- Read access to one dataset, for a group, in BigQuery's own SQL
2 GRANT `roles/bigquery.dataViewer`
3   ON SCHEMA `lk-warehouse-prod.curated`
4   TO "group:analysts@larkspur.energy";
5
6 -- Job User is project-level, so it is granted with IAM, not SQL
7 gcloud projects add-iam-policy-binding lk-analytics-prod \
8   --member="group:analysts@larkspur.energy" \
9   --role="roles/bigquery.jobUser"
```

3 SCHEMA means dataset. The grant stops at curated, so raw stays private.

4 A group, never a list of people. Joiners and leavers change the group, not the policy.

9 The query runs and is billed in the analytics project, not the warehouse.

THE TAKEAWAY

Grant to groups, at the lowest level that does the job. That sentence answers a lot of questions.

Buckets: one rule for every object

- **Uniform bucket-level access** turns off per-object ACLs. Access comes from IAM only.
- Enforced by default for **organisations created since 3 May 2024**.
- **Public access prevention** stops anyone making the bucket or its objects public.
- **Fine-grained ACLs** on single objects are the legacy model and hard to audit.

> ON THE EXAM
>
> If an option manages access object by object, it is almost always the wrong one.

A pipeline is not a person. It runs as a **service account**, and that account needs its own least privilege.

Three identities behind every Dataflow job

01

The launcher

You or Cloud Build. Needs Service Account User on the worker account.

02

Dataflow service agent

Google-managed. Checks quota and starts the worker VMs.

03

Worker service account

What the code runs as. Reads sources, writes sinks.

ON THE EXAM

By default, workers run as the Compute Engine default service account. Replace it with your own, least privilege.

Keys, or something better

SERVICE ACCOUNT KEY

A copy of the master key

- Long-lived until someone deletes it
- Can leak through code, laptops, tickets
- Audit logs show the account, not who used it
- Blocked by default on newer organisations

KEYLESS OPTIONS

A visitor badge that expires

- Attach the account to the VM, job or function
- Impersonate it, with Token Creator
- Workload Identity Federation for outside systems
- Short-lived tokens, both names in the logs

THE TIEBREAKER

If an option creates a key and stores it somewhere, it is almost always the wrong option.

IAM conditions: when, and on what

- **Time-bound access.** A contractor's role that expires on a set date, with no one remembering to remove it.
- **Resource name.** Access to tables or objects whose names start with a prefix.
- Conditions attach to a **grant**, so you narrow a predefined role rather than inventing a custom one.
- A condition still only narrows a grant. It cannot block a principal who has access another way.

> ON THE EXAM
>
> Temporary access is a conditions question. 'Remember to revoke it' is never the exam's answer.

IAM decides **who** can act. Organisation policies decide **what is allowed at all**, even for owners.

Constraints a data engineer meets

CONSTRAINT	WHAT IT ENFORCES
gcp.resourceLocations	New resources only in allowed locations, e.g. Frankfurt.
iam.allowedPolicyMemberDomains	Grants only to identities in your own domain.
storage.uniformBucketLevelAccess	No per-object ACLs on any bucket.
storage.publicAccessPrevention	Nothing in Cloud Storage can be made public.
compute.vmExternalIpAccess	VMs, including Dataflow workers, get no external IP addresses.
iam.managed.disableServiceAccountKeyCreation	No new service account keys.

WATCH FOR

No external IPs on workers means Private Google Access. Module 10.

Secure by default, since May 2024

- Organisations created **on or after 3 May 2024** start with seven constraints already enforced.
- **Service account keys** cannot be created or uploaded.
- **Default service accounts** no longer receive the Editor role automatically.
- **Domain restricted sharing** and **uniform bucket-level access** are on.
- Older study material often answers with a downloaded key. On a new organisation, that fails.

> ON THE EXAM
>
> If a scenario hits an organisation policy error when creating a key, the fix is keyless, not disabling the policy.

Resource locations: what it does and does not do

- Set it on a **folder**, and every project below inherits it. Larkspur sets Frankfurt on the de folder.
- **Not retroactive.** It applies only to newly created resources. Audit what already exists.
- **Global resources**, and ones without a location choice, are not affected.
- It controls **where resources are created**. Google says it is not a data storage commitment.

> COMING UP
>
> For full residency guarantees, add Assured Workloads and VPC Service Controls. Module 05 builds that design.

IAM or organisation policy?

USE IAM WHEN

It is about a principal

- A person or workload needs access
- Access should be narrowed or expire
- Different teams need different data
- Granted by resource owners

USE AN ORG POLICY WHEN

It is about a setting

- No one may ever choose that setting
- Owners must be bound too
- It must apply across many projects
- Set centrally, inherited down

THE TIEBREAKER

A question about who: IAM. A question about what nobody may configure: organisation policy.

When you really must remove access

- **Remove the grant** where it was made. Usually the right answer, and usually higher up than you think.
- **Deny policies** block chosen permissions, whatever any allow policy says. Checked before allows.
- **Principal access boundaries** limit which resources a principal is eligible to reach at all.
- Adding a narrower role lower down removes nothing. That is the classic distractor.

> ON THE EXAM
>
> If a user still has access after you tightened a dataset, look up the hierarchy for an inherited grant.

> Larkspur's warehouse lives in project lk-warehouse-prod, with datasets raw, curated and marts. Sixty analysts, all in the group analysts@larkspur.energy, run their queries from project lk-analytics-prod.
>
> They need to query the curated dataset. They must not be able to read raw, which still holds unmasked personal data.

Which access design follows least privilege?

A Grant BigQuery Data Viewer to the analysts group on project lk-warehouse-prod

B Grant BigQuery Admin to the analysts group on the curated dataset

C Grant Data Viewer on the curated dataset and Job User on lk-analytics-prod, both to the group

D Grant the Viewer basic role on both projects to each analyst individually

◆ PAUSE AND DECIDE

Which access design follows least privilege?

A Data Viewer on the warehouse project

A project grant flows down to every dataset, including raw. And nothing here lets them run a query.

B BigQuery Admin on curated

Far more than reading: they could change data and access. Still no permission to run jobs.

C Data Viewer on curated, Job User on the analytics project

Read access stops at curated, and queries run and bill where they belong. Granted to a group.

D Viewer basic role, per person

A basic role is too broad, reaching raw too, and sixty individual grants are impossible to keep tidy.

THE SIGNAL

'Must not read raw' rules out any project-level data grant. Reading and running are two separate grants.

> Larkspur's streaming Dataflow job in lk-ingest-prod reads a Pub/Sub subscription and writes to the BigQuery raw dataset. It runs as the Compute Engine default service account, which holds the Editor role. Cloud Build launches the job.
>
> A security review demands least privilege, with no long-lived credentials.

What should the team do?

A. Create a dedicated worker service account with only the roles the job needs, and let Cloud Build act as it

B. Keep the default service account, remove Editor, and grant it Owner on the raw dataset

C. Create a key for a new service account and store it in Cloud Storage for the job to load

D. Grant the Dataflow service agent Pub/Sub Subscriber and BigQuery Data Editor on the project

◆ PAUSE AND DECIDE

What should the team do?

A Dedicated worker account; Cloud Build acts as it

Dataflow Worker, Subscriber on one subscription, data roles on raw only. Cloud Build gets Service Account User.

B Default account, Owner on raw

Other services share the default account, and Owner can change access to raw. Least privilege it is not.

C A key stored in Cloud Storage

A long-lived credential sitting in a bucket. The review ruled this out, and new organisations block it.

D Roles on the Dataflow service agent

The service agent starts workers. Your code runs as the worker account, so these grants miss.

THE SIGNAL

'Runs as the default service account' is a signal. The fix is a dedicated worker account, not a bigger grant.

German customer data must stay in Germany. All of Larkspur Energie's projects sit in the de folder.

The security team needs a guarantee that nobody, project owners included, can create a BigQuery dataset or Cloud Storage bucket outside Frankfurt in any current or future project in that folder.

What should the security team do?

A Remove the Owner role from everyone on the projects in the de folder

B Add an IAM condition to BigQuery Data Editor grants that checks the dataset's location

C Deploy a Cloud Run function that deletes any dataset or bucket created outside europe-west3

D Set the resource locations constraint on the de folder to in:europe-west3-locations

◆ PAUSE AND DECIDE

What should the security team do?

A Remove Owner from everyone

Other roles can still create datasets and buckets anywhere. Fewer owners is not a location rule.

B An IAM condition on Data Editor

Narrows one grant for one role. Owners and other roles are untouched, so it is not a guarantee.

C A function that deletes violations

Reactive. The data has already landed outside Germany before anything is deleted.

D Resource locations constraint on the folder

Blocks creation outside Frankfurt for everyone, and every future project inherits it.

THE SIGNAL

'Nobody, owners included' plus 'future projects' is organisation policy language, set on the folder.

> Larkspur's Google Cloud organisation was created in 2025. Its deployment pipeline runs in GitHub Actions, outside Google Cloud, and must deploy Dataflow templates to lk-ingest-prod.
>
> An engineer tries to create a service account key for the pipeline and gets an organisation policy error. The team wants no long-lived credentials and no new infrastructure to run.

What should the team do?

A. Ask an administrator to disable the key creation constraint, then store the key as a GitHub secret

B. Use Workload Identity Federation so the pipeline can impersonate a deployment service account

C. Store a senior engineer's own credentials in the pipeline, since that account already has access

D. Run a self-hosted runner on a VM with the deployment service account attached

◆ PAUSE AND DECIDE

What should the team do?

A. Disable the constraint and store a key

Switches off a deliberate safeguard to create the long-lived credential the team said it did not want.

B. Workload Identity Federation for GitHub

GitHub's own identity token is exchanged for short-lived Google credentials. No key, nothing to run.

C. A person's credentials in the pipeline

Ties production to one human, breaks when they leave, and the logs blame them for every deployment.

D. Self-hosted runner on a VM

Keyless, and it would work. But it is new infrastructure to patch and run, which the team ruled out.

THE SIGNAL

An outside system plus 'no keys' is Workload Identity Federation. The policy error is a hint, not a bug.

Module 02 in five lines

- Grants flow **down** and only **add**. A narrower grant lower down removes nothing.
- **Predefined roles, to groups, at the lowest level** that does the job. Never basic roles.
- BigQuery needs two grants: a **data role** where data lives, **Job User** where queries run.
- Workloads get **dedicated service accounts** and **keyless** credentials.
- **Nobody, owners included** means an organisation policy, set on a folder or the organisation.

COMING UP

Next: module 03, encryption and key management.